

Preparing a Risk Management Plan (3e)

Managing Risk in Information Systems, Third Edition - Lab 03

Student:

Karnelius Sindhu

Email:

karneliussindhu6329@gmail.com

Time on Task:

Progress:

100%

Report Generated: Monday, February 24, 2025 at 5:59 PM

Guided Exercises

Part 1: Research the NIST Risk Management Framework

4. **Explain** Figure 1: Organization-wide Risk Management Approach.

An enterprise-wide risk management strategy is a business-wide process whereby a company detects, analyzes, and oversees prospective risks at all departments and levels. It presents one perspective of threats and facilitates concerted action to combat them. Rather than managing risks in secessionist departments, it brings risk management into the whole business.

6. Briefly **explain** two of the items from the preparation list.

Two items that are really important in preparation step is to achieve more effective, efficient, and cost effective security and privacy risk management process.

Risk Identification and assessment involves identification of risk concerned to privacy and security that can effect the organization. From Deep vulnerability , threat actors and of security breaches

8. **Provide** a reason why you think the risk decisions at Levels 1 and 2 can impact the selection and implementation of controls at the System level.

Risk decisions at level 1 and 2 can impact the selection and implementation of control at the system level, because the security controls are inherited from the system , and also they establish overall risk appetite and direction for organization

10. **Summarize** Figure 2: Risk Management Framework.

Risk Management Framework (RMF) is a process through which organizations can efficiently manage privacy and security risks. It is divided into seven major steps starting from the preparation stage, wherein organizations define priorities and readiness to manage risks. They categorize the system as per the sensitivity of the data it processes. Second, they select appropriate security controls to mitigate threats, and subsequently deploy these controls within the system. After deployment, the controls are tested to ensure that they function as intended. If the risk is tolerable, the system is ready for use. Finally, organizations regularly monitor the system, reassessing risks, maintaining and updating, and ensuring compliance. This end-to-end process ensures an engaged and reactive risk management process.

12. Briefly **explain** why the Monitor step is needed. **Provide** two examples of what the Monitor step should cover.

The Monitor step of the Risk Management Framework (RMF) is essential as it offers continuous monitoring of the system's security posture, detects emerging threats, and maintains compliance with security and privacy controls. By continuously assessing the effectiveness of controls, organizations can respond promptly to new risks and system changes.

Examples of what the Monitor step should contain:

Measuring Control Effectiveness – Periodically checking if security controls are operating as they should and preventing threats as expected.

System Change Tracking – Tracking system changes, such as software updates or configuration changes, to ensure they do not introduce new vulnerabilities.

14. **Select** one of the 18 preparation tasks and briefly **explain** that specific task.

TASK P-10 Asset identification Identify asset that requires protection

Owner: System Owner

Supporting Roles: Authorizing Official or Authorizing Official Designated Representative • Mission or Business Owner • Information Owner or Steward • Senior Agency Information Security Officer • Senior Agency Official for Privacy • System Administrator

Explanation: So the assets can be digital assets also or the physical assets, obviously the digital assets can be SPII or PII. Also the physical assets can be GSS(General Support System), Laptops or Servers. So, basically it involves clearly understanding the assets the company own, locations. In order to identify we need to create an inventory of all or we need to collect the inventory as well also we need to set a system authorization boundary where the control of the system starts and end.

16. **Select** one associated title (for example, Head of Agency, Authorizing Official, Business Owner) and **identify** at least two of their main duties related to the task you selected.

The Head of Agency performs these two main tasks

information security and privacy management processes are integrated with strategic and operational planning processes.

- Senior officials within the organization provide information security for the information and systems supporting the operations and assets under their control.

18. **Select** one associated title and **identify** at least two of their main duties related to the task you selected.

So for example for the system administrator, the primary roles for system administrator is to install, configure hardware and softwares, managing the user account over seeing or conducting backup. So what actually they do with the help of security team they perform vulnerability assessments also help them to identify the threats and also in compliance checks

Part 2: Create a Risk Management Plan

2. **Select** one task from Table 1 on page 28 and **describe** how the task could help Acme achieve its goal of creating a robust risk management plan.

Task P1 RISK MANAGEMENT ROLES:

So in order to mitigate risk I would implement Risk management roles, which helps the organization to assign the specific task to only the specific roles, it helps the organization to be specific with the roles and responsibilities. And also encourage RBAM (Role Based Access Model). It will help the organization in access control as well.

5. In the context of the recent PCI DSS audit findings at Acme Corporation, **identify** a clause that describes the assets requiring protection.

So in order to protect these intangible information, the protection requires stakeholders concerns and the context in which the assets are used

8. **Describe** the system at Acme Corporation that was audited recently.

The system that is in ACME Corporation which is recently audited is Account management process which includes credit card processing and also the vulnerabilities associated with inactive users

11. **Describe** two controls that could help mitigate the findings in the PCI DSS audit. One control should be in the information system tier and one control should be in the Organization or Mission/Business Process level.

Information System Tier Control: As per this control is the implementation of encryption of cardholder data.

Organization/Mission/Business process level control: Cybersecurity awareness and training of employees

14. **Describe** how the two controls you selected should be implemented.

Access Control(AC-2)Implementing a robust identify and access management control. Network Access Control: Implementation of network segmentation for isolation of sensitive system.

17. Which Assess task should you follow after completing Task A-3? **Specify** the code and name of the task from Table 6 on page 61.

Task A4A-4: Assess Control Effectiveness

Since account security control have already been implemented individual also has been assigned to look after the account management its focuses on determining if the security control are operating at good level or not means effectively. this helps to identify any gaps or area to improve

20. **Assume** the role of a top-level manager. What authorization decision would you make and why?

I would go with Conditionally Approve one. to approve the system for operation, pending the completion of the task, account compliance and monitoring. Because here security control would be implemented and access control it also help in Risk mitigation through conditional approval

22. **Think** about the vulnerability of a lack of account management procedure. Which monitor tasks would you suggest to monitor the implementation of this control and the authorization of the implementation? Who would be the responsible parties for these tasks?

I would say Task M3 ongoing Risk response Mean output of continuous monitoring activities is analyzed and responded to appropriately.

Because it helps to review the new account creation users. and Account modification monitoring. Responsible parties Security Officer and IT manager

Challenge Exercise

Carefully review this report and **identify** two vulnerabilities from different organizational levels, such as one vulnerability from Level 3 and one vulnerability from Level 1 or 2.

Vulnerabilities

- 1 - Level 3 Vulnerability: Apache Struts VulnerabilityHackers exploited the yet-to-be patched Apache Struts vulnerability (CVE-2017-5638), exposing sensitive data of 150 million people
2. Level 2 Vulnerability: Patch Management Failure Equifax failure to apply its policy of patching critical vulnerabilities within 48 hours created room for the breach to occur.

Now think about the seven steps of the RMF. **Summarize** how these steps could have helped Equifax prevent or mitigate the vulnerabilities you identified. **Identify** at least one step for each vulnerability.

- RMF Application 1. Categorize Information Systems (Level 2 - Patch Management Failure): Enhanced system categorization would prioritize patching and security for critical systems, reducing patch lag.
2. Select Security Controls (Level 3 - Apache Struts): Implement stronger security controls like automated vulnerability scanning and firewall protections for critical systems with Apache Struts.
3. Implement Security Controls (Level 2 - Patch Management Failure): Implement patch management process and ensure on-time patching through automated processes.
4. Assess Security Controls (Level 3 - Apache Struts): Regular vulnerability scanning would have detected the unpatched vulnerability before it was exploited.
5. Approve Information System (Level 2 - Patch Management Failure): Security controls on vital systems need to be checked at regular intervals to ensure compliance with patch policies.
6. Continuous Monitoring of Security Controls (Level 2 - Patch Management Failure): Continuous monitoring would have caught delay in deployment of patches and addressed them ahead of time.
7. Continuous Improvement (Level 2 & 3 - Both Vulnerabilities): Post-breach reviews would identify technical control and internal process weaknesses, refining future risk management strategies.